

ТЕХНИЧЕСКИЙ ОТЧЁТ

Безопасность, ликвидация N+1, асинхронность и масштабирование (2000–5000 VU)

Модуль тестирования
Дата: 27 августа 2026 г.
Версия: 2.4.0 Production
Ready

1. Информационная безопасность (Security Hardening)

ЗАЩИЩЕНО Защита от CSRF Внедрён стандарт <i>Double-Submit Cookie</i>. При старте сессии формируется защищённый токен <code>asmt_csrf_token</code>, автоматически отправляемый через заголовок <code>X-CSRF-Token</code> на все мутирующие запросы. При несовпадении возвращается HTTP 419.	ОЧИЩЕНО Устранение утечек и дампов Удалены неиспользуемые отладочные скрипты <code>debug-dump.php</code> и <code>debug2.php</code>. Банк правильных ответов и дампы пользователей изолированы от прямого доступа.
ВНЕДРЕНО Заголовки безопасности Сконфигурированы заголовки <code>X-Frame-Options</code>: <code>SAMEORIGIN</code>, <code>X-Content-Type-Options</code>: <code>nosniff</code>, <code>Referrer-Policy</code>, <code>HSTS</code> и базовая CSP на уровне веб-сервера и PHP.	НАДЁЖНО Защита IP и стектрейсов Чтение <code>X-Forwarded-For</code> разрешено строго от доверенных прокси (RFC1918). Вывод внутренних стектрейсов <code>\$e->getMessage()</code> скрыт от клиентов и переведён в структурированный <code>error_log()</code>.

2. Ликвидация N+1 запросов и оптимизация СУБД

КОМПОНЕНТ	БЫЛО (ПРОБЛЕМА)	СТАЛО (ОПТИМИЗАЦИЯ)
Формирование билета (<code>attempt-start.php</code>)	41 запрос на билет (1 запрос на вопрос + 40 запросов вариантов)	2 пакетных запроса через <code>WHERE question_id IN (...)</code> с группировкой в ассоциативный массив PHP.
Оценка ответов (<code>AttemptService.php</code>)	40 последовательных <code>UPDATE</code> в цикле	1 пакетный <code>UPDATE ... FROM (VALUES)</code> в одной транзакции.
Личный кабинет (<code>cabinet.php</code>)	Цикл пересчёта и мутаций при каждом открытии ЛК	100% Read-Only режим . Исторический пересчёт вынесен в изолированный скрипт.
Кэш пользователя (<code>Auth.php</code>)	Повторные запросы к <code>asmt_users</code> при каждой проверке роли	In-Memory статический кэш с инвалидацией при <code>login/logout</code> .
Телеметрия сети (<code>attempt-ping.php</code>)	Чтение всего JSON в PHP, модификация и запись назад	Нативная конкатенация PostgreSQL <code>telemetry_json ?::jsonb</code> .

3. Индексация СУБД и локальное кэширование DaData

- **Композитные индексы PostgreSQL:** созданы без блокировок (CONCURRENTLY) по (user_id, status, expires_at), (user_id, campaign_id, status), (user_id, requested_at DESC) и частичный индекс по активным попыткам WHERE status = 'in_progress'.
- **Кэш DaData (24 часа):** таблица asmt_dadata_cache с автоматическим сохранением реквизитов организаций по ИНН. Устраняет задержки до 6 сек при регистрации и лимиты API.
- **Фоновый сборщик зависших попыток:** скрипт scripts/expire_orphan_attempts.php для регламентного закрытия протухших попыток по Cron.

4. Асинхронная почтовая система (Mail Queue)

Синхронная отправка писем блокировала PHP-воркер на 1–3 секунды. Реализована отказоустойчивая асинхронная архитектура:

- **Мгновенная постановка в очередь:** вызов Mailer::queue() выполняется за < 1 миллисекунды, сохраняя задачу в таблицу asmt_mail_queue.
- **Приоритеты:** priority = 10 для критических писем (восстановление пароля, коды входа), priority = 50 для информационных уведомлений.
- **Фоновый обработчик (scripts/process_mail_queue.php):** отправка сообщений пачками до 50 штук с переиспользованием SMTP-сокета.
- **Экспоненциальный Backoff и DLQ:** интервалы повторов при сбоях сети (30 сек → 2 мин → 10 мин → 1 час), перемещение в Dead-Letter Queue (статус failed) после 5 попыток.

5. Редизайн и интерфейсная эргономика

- **Шапка и Бургер-навигация:** во всех 8 разделах админки реализовано компактное выпадающее меню с бейджами событий в реальном времени.
- **Высокоплотные таблицы 100% ширины:** устранён горизонтальный скролл в разделах «Пользователи», «Запросы на передачу» и «Статистика». Кнопки действий заменены на компактные квадратные иконки ([i], [✓], [X]).
- **Модальные окна глубокой детализации:** подробные анкеты, структура подчиненности организаций, сетевая телеметрия и параметры сессии вынесены в интерактивные модальные окна.

6. Инструкция по тестированию и регламентным задачам

1. Настройка фоновых задач (Cron на сервере):

```
* * * * * php /var/www/CRZRT-Redesign/assessment/scripts/process_mail_queue.php > /dev/null 2>&1
0 * * * * php /var/www/CRZRT-Redesign/assessment/scripts/expire_orphan_attempts.php > /dev/null 2>&1
```

2. Ручной тест отправки почтовой очереди:

```
# 1. Запросить восстановление пароля на сайте
# 2. Проверить запись в очереди:
sudo -u postgres psql -d asmt -c "SELECT id, to_email, subject, status, next_retry_at FROM asmt_mail_queue
ORDER BY id DESC LIMIT 3;"
# 3. Принудительно запустить воркер:
php assessment/scripts/process_mail_queue.php
```

3. Нагрузочное тестирование k6 (200 и 2000 VU):

```
# Базовый Smoke-тест (200 пользователей):
k6 run assessment/load/k6-smoke.js

# Стресс-тест с рампингом (2000 пользователей):
k6 run assessment/load/k6-load.js
```